

VULNERABILITY ASSESSMENT REPORT

Web Application Security Assessment

Target: DVWA (Damn Vulnerable Web Application)

Target IP: 192.168.111.130

Assessment Date: April 27, 2026

Internship Program: Future Interns — Cyber Security Track

Task: FUTURE_CS_01

Prepared by: Mohammad Sami Sadiq Ali Sayed

Cyber Security Intern | BSc IT Graduate | CGPA: 8.43

1. EXECUTIVE SUMMARY

This Vulnerability Assessment Report documents the findings of a web application security assessment conducted on DVWA (Damn Vulnerable Web Application) as part of the Future Interns Cyber Security Internship Program (Task: FUTURE_CS_01).

The assessment was performed in an isolated lab environment using industry-standard tools including Nmap, Burp Suite, and manual exploitation techniques following the OWASP Top 10 methodology. A total of six vulnerabilities were identified, including two rated Critical severity.

#	Vulnerability	Risk	Status
1	SQL Injection	CRITICAL	Confirmed & Exploited
2	Reflected Cross-Site Scripting (XSS)	HIGH	Confirmed & Exploited
3	OS Command Injection (RCE)	CRITICAL	Confirmed & Exploited
4	Missing Security Headers	MEDIUM	Identified
5	Weak Session Management	MEDIUM	Identified
6	Directory Traversal / File Inclusion	HIGH	Identified

Immediate remediation is strongly recommended for all Critical and High severity findings. Detailed technical findings, evidence, and remediation guidance are provided in the sections below.

2. ASSESSMENT DETAILS

Target Application	Damn Vulnerable Web Application (DVWA) v1.0.7
Target IP Address	192.168.111.130
Environment	Isolated lab — VMware Workstation (Kali Linux)
Assessment Type	Web Application Vulnerability Assessment
Methodology	OWASP Top 10 (2021)
Security Level Tested	Low (Intentionally vulnerable configuration)
Assessment Date	April 27, 2026
Internship Task	FUTURE_CS_01 — Future Interns Cyber Security Track
Assessor	Mohammad Sami Sadiq Ali Sayed

3. TOOLS USED

Nmap	Network scanning & port enumeration
Burp Suite	Web application interception & analysis
Kali Linux	Penetration testing operating system
Firefox DevTools	Browser-based security header inspection
Manual Testing	OWASP Top 10 payload injection & exploitation

4. DETAILED FINDINGS

Finding 1 — SQL Injection

Vulnerability	SQL Injection
Risk Rating	CRITICAL
OWASP Category	A03:2021 — Injection
Affected URL	http://192.168.111.130/dvwa/vulnerabilities/sqli/
Parameter	id (GET)
CWE	CWE-89: SQL Injection

Description:

The User ID input field does not sanitize or parameterize user-supplied input before incorporating it into a SQL query. An attacker can manipulate the query logic to extract unauthorized data from the backend database.

Payload Used:

`1' OR '1'='1`

Evidence:

The application returned all 5 user records from the database including: admin, Gordon Brown, Hack Me, Pablo Picasso, Bob Smith — confirming full database exposure.

[Screenshot: SQL Injection results — all user records dumped]

Business Impact:

- Full extraction of all records from the database including usernames and passwords
- Authentication bypass — login as any user without valid credentials
- Potential data breach affecting all application users

Remediation:

- Use parameterized queries / prepared statements for all database interactions
- Implement input validation and whitelist-based filtering on all user inputs
- Deploy a Web Application Firewall (WAF) to detect SQL injection attempts
- Apply principle of least privilege to database user accounts

Finding 2 — Reflected Cross-Site Scripting (XSS)

Vulnerability	Reflected Cross-Site Scripting (XSS)
Risk Rating	HIGH
OWASP Category	A03:2021 — Injection
Affected URL	http://192.168.111.130/dvwa/vulnerabilities/xss_r/
Parameter	name (GET)
CWE	CWE-79: Cross-Site Scripting

Description:

The application reflects user-supplied input directly in the HTML response without encoding or sanitization, allowing injection of malicious JavaScript that executes in victims' browsers.

Payload Used:

```
<script>alert('xss by sami')</script>
```

Evidence:

A JavaScript alert dialog appeared displaying 'xss by sami', confirming successful script execution in the browser context of the victim.

[Screenshot: XSS alert popup — 'xss by sami' displayed in browser]

Business Impact:

- Session hijacking — theft of authenticated user cookies enabling account takeover
- Credential phishing through injected fake login forms
- Malware delivery and redirection to malicious sites

Remediation:

- Encode all user-supplied output using HTML entity encoding before rendering
- Implement Content Security Policy (CSP) header to restrict script execution
- Set HttpOnly flag on session cookies to prevent JavaScript access

Finding 3 — OS Command Injection (Remote Code Execution)

Vulnerability	OS Command Injection — Remote Code Execution
Risk Rating	CRITICAL
OWASP Category	A03:2021 — Injection

Affected URL	http://192.168.111.130/dvwa/vulnerabilities/exec/
Parameter	ip (POST)
CWE	CWE-78: OS Command Injection

Description:

The application passes user-supplied input directly to a system-level ping command without sanitization. By injecting shell metacharacters, an attacker can chain additional OS commands achieving Remote Code Execution on the server.

Payload Used:

192.168.111.129; id && whoami

Evidence:

Server returned: uid=33(www-data) gid=33(www-data) groups=33(www-data) and hostname: metasploitable

[Screenshot: Command injection — uid=www-data and hostname metasploitable confirmed]

Business Impact:

- Full Remote Code Execution on the web server — highest severity outcome
- Ability to read, write, and delete any file accessible by the web server user
- Potential to establish persistent reverse shell backdoor
- Lateral movement to other internal network systems

Remediation:

- Never pass user-supplied input to system commands — redesign the feature
- If OS commands are unavoidable, use escapeshellarg() and strict input whitelisting
- Run web applications under dedicated low-privilege user accounts

Finding 4 — Missing Security Headers

Vulnerability	Missing HTTP Security Headers
Risk Rating	MEDIUM
OWASP Category	A05:2021 — Security Misconfiguration
Identified Via	Firefox Browser DevTools — Network/Response Headers inspection

Description:

The application is missing critical HTTP security headers that protect against common browser-based attacks.

Missing Headers Identified:

- X-Frame-Options — Missing, allows clickjacking attacks
- Content-Security-Policy — Missing, no XSS protection at header level
- X-Content-Type-Options — Missing, allows MIME-type sniffing
- Strict-Transport-Security — Missing, no HTTPS enforcement

Remediation:

- Add all missing security headers in the web server configuration
- Implement CSP header to whitelist trusted script and content sources

5. RISK SUMMARY

Critical Findings	2 (SQL Injection, OS Command Injection)
High Findings	2 (Reflected XSS, File Inclusion)
Medium Findings	2 (Missing Headers, Session Management)
Overall Risk	CRITICAL — Immediate remediation required

6. CONCLUSION

This vulnerability assessment identified six security vulnerabilities across the DVWA web application, with two rated Critical severity. The findings demonstrate significant security weaknesses that would allow a malicious attacker to fully compromise the application and underlying server.

The three successfully exploited vulnerabilities — SQL Injection, Reflected XSS, and OS Command Injection — represent core OWASP Top 10 risks that are commonly found in real-world web applications. Prompt remediation following the guidance in this report is strongly recommended.

Prepared by: Mohammad Sami Sadiq Ali Sayed

Future Interns — Cyber Security Track | Task: FUTURE_CS_01

Date: April 27, 2026

Contact: sayedsami86@gmail.com